

Fundamentos de arquitectura

Actividad 6 – JWT Tokens

Estudiantes:

Albertos Sosa Danna Pamela

Cetzal Cetzal Astrit Airan

Díaz Anduze Giovana Ruby

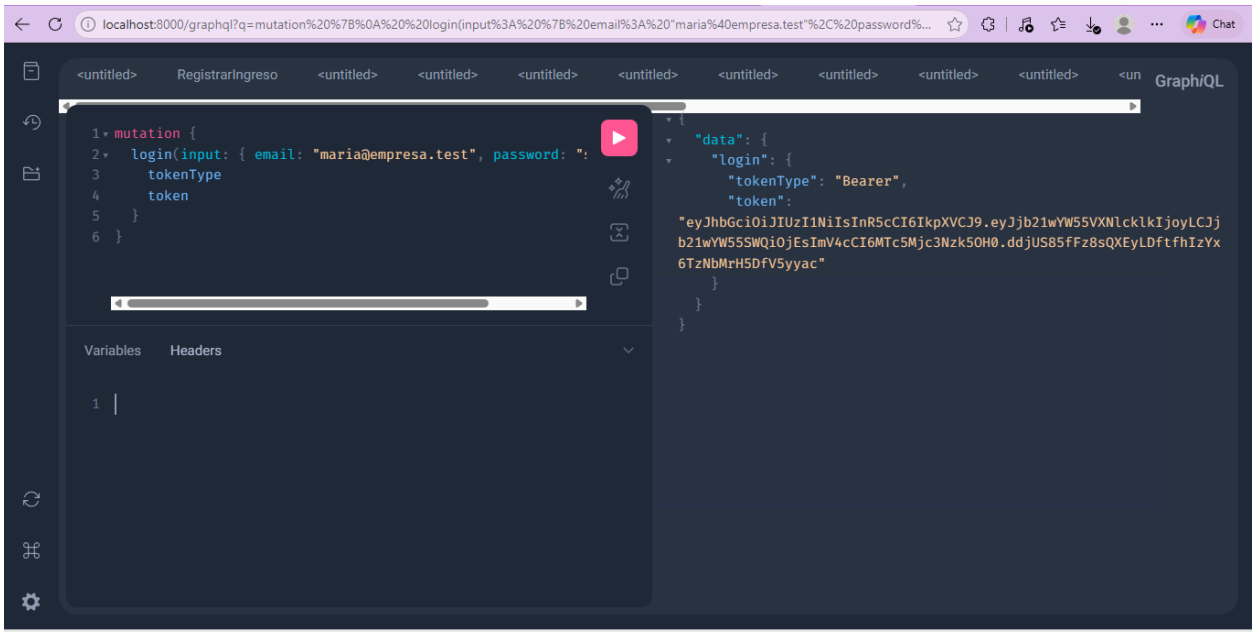
Semino Alemán Venus Getsemaní

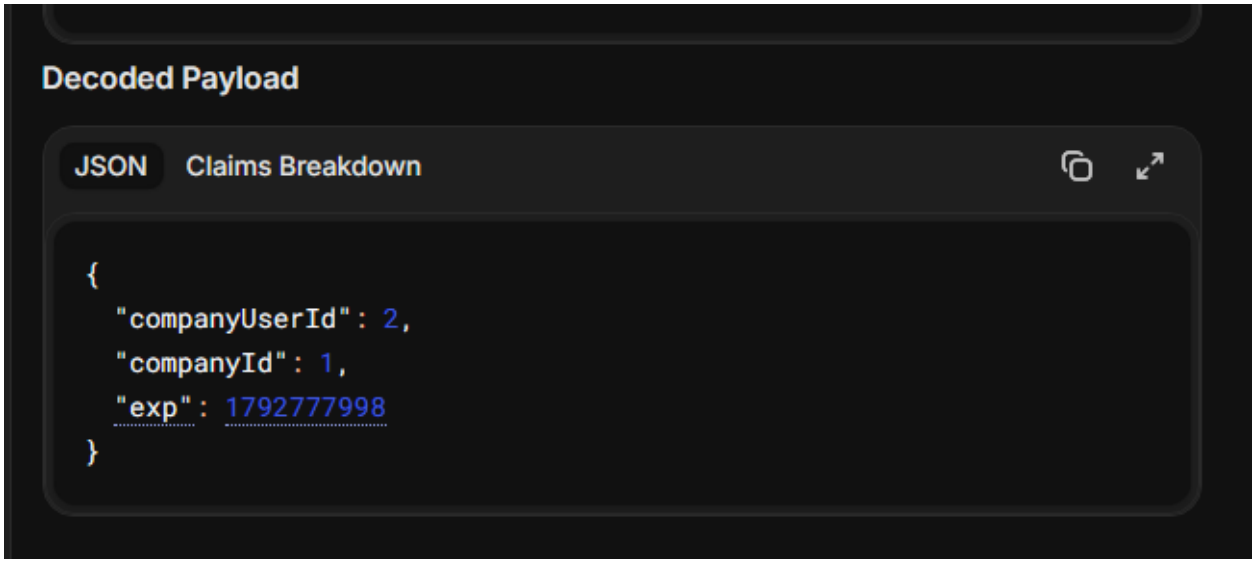
Docente:

Gimer Almicar Cervera Evia

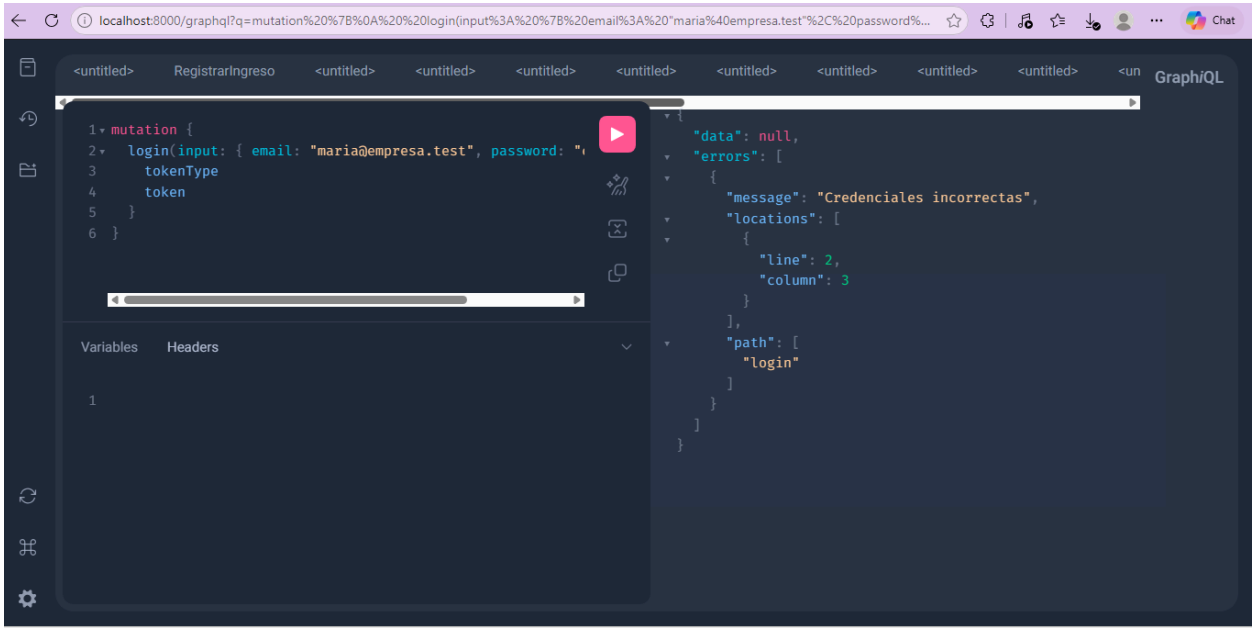
4°A

Mérida, Yucatán a 20 de octubre de 2026

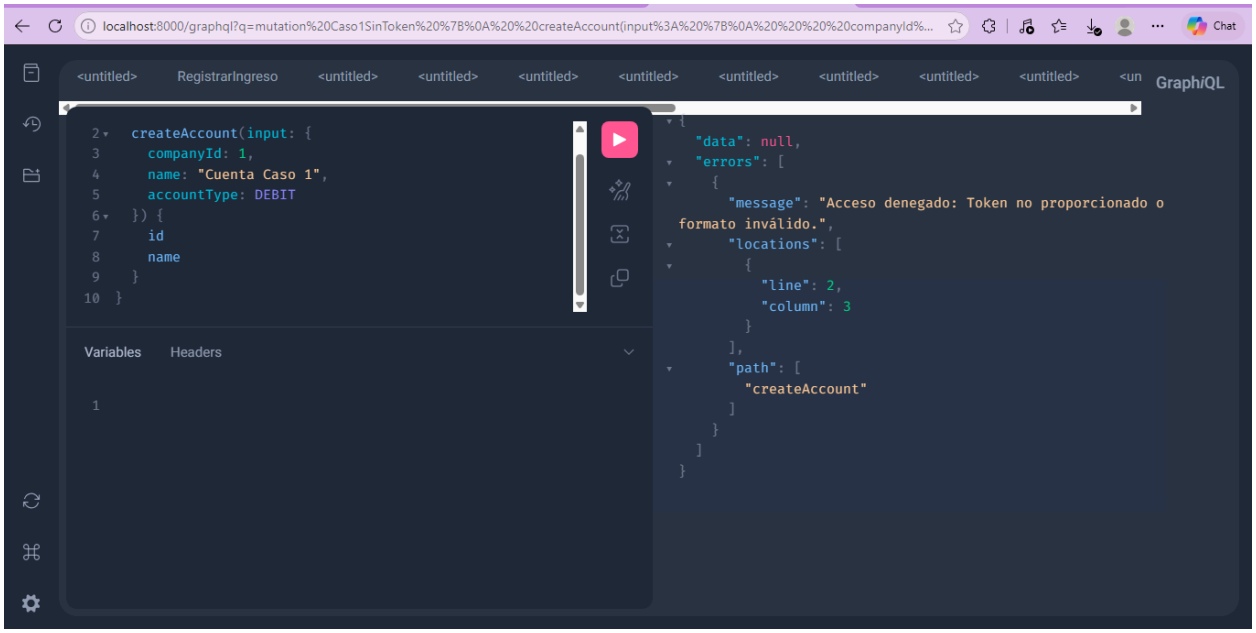

localhost:8000/graphql?q=mutation%20%7B%0A%20%20login(input%3A%20%7B%20email%3A%20"maria%40empresa.test"%2C%20password%...
Chat
<untitled>
RegistrarIngreso
<untitled>
<untitled>
<untitled>
<untitled>
<untitled>
<untitled>
<untitled>
<untitled>
<un
GraphiQL
1 mutation {
2 login(input: { email: "maria@empresa.test", password: "
3 tokenType
4 token
5 }
6 }
{
"data": {
"login": {
"tokenType": "Bearer",
"token":
"eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJjb21wYW55VXNlcklkIjoyLCJjb21wYW55SWQiOjEsImV4cCI6MTc5Mjc3Nzk5OH0.ddjUS85fFz8sQXEyLDftfhIzYx6TzNbMrH5DfV5yyac"
}
}
}
Variables
Headers
1


Decoded Payload
JSON
Claims Breakdown
{
"companyUserId": 2,
"companyId": 1,
"exp": 1792777998
}

Login rechazado

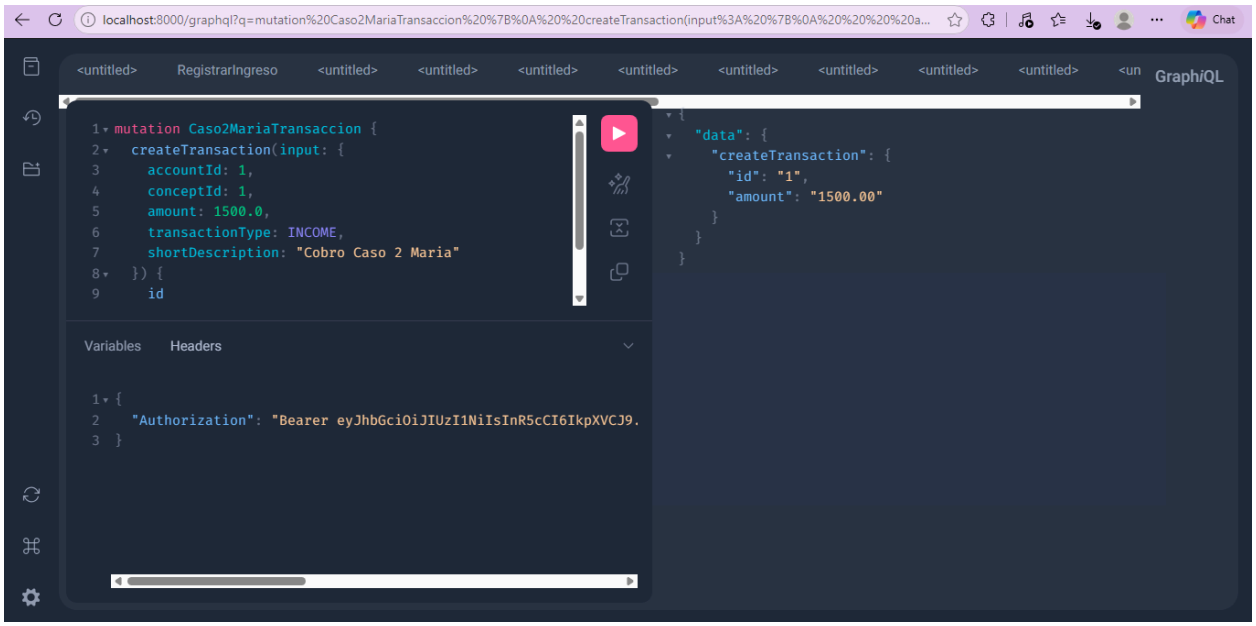


Caso 1: createAccount sin token (Rechazado)



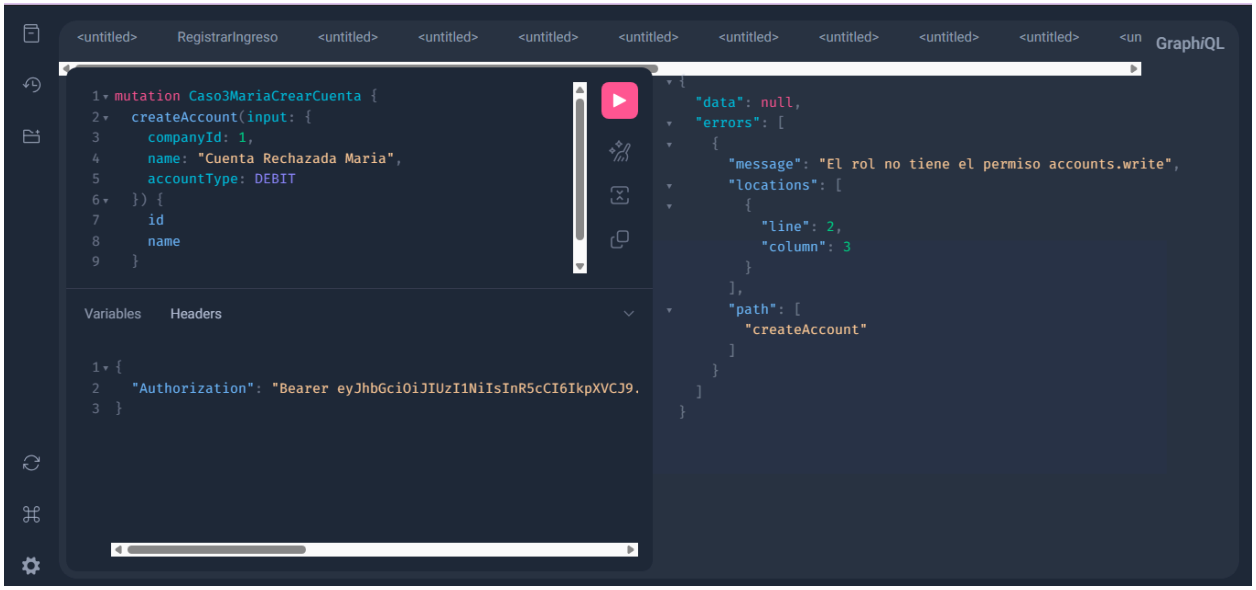
```
(venv) PS C:\Users\cetza\ArqSoft-DevBack\U2_Actividad4\U2
-Actividad-3---Roles-y-Control-de-Acceso\Actividad06-JWT
Tokens> python -c "import sqlite3; conn=sqlite3.connect('
sistema.db'); r=conn.cursor().execute(open('consulta.sql'
, encoding='utf-8').read()).fetchall(); print(f'Filas enc
ontradas: {len(r)}'); print(r)"
Filas encontradas: 0
[]
(venv) PS C:\Users\cetza\ArqSoft-DevBack\U2_Actividad4\U2
-Actividad-3---Roles-y-Control-de-Acceso\Actividad06-JWT
Tokens>
```

Caso 2: Registro exitoso de createTransaction por María (Rol Capturista).
Regla que demuestra: El rol CAPTURISTA posee el permiso `transactions.write` y puede registrar transacciones válidas.



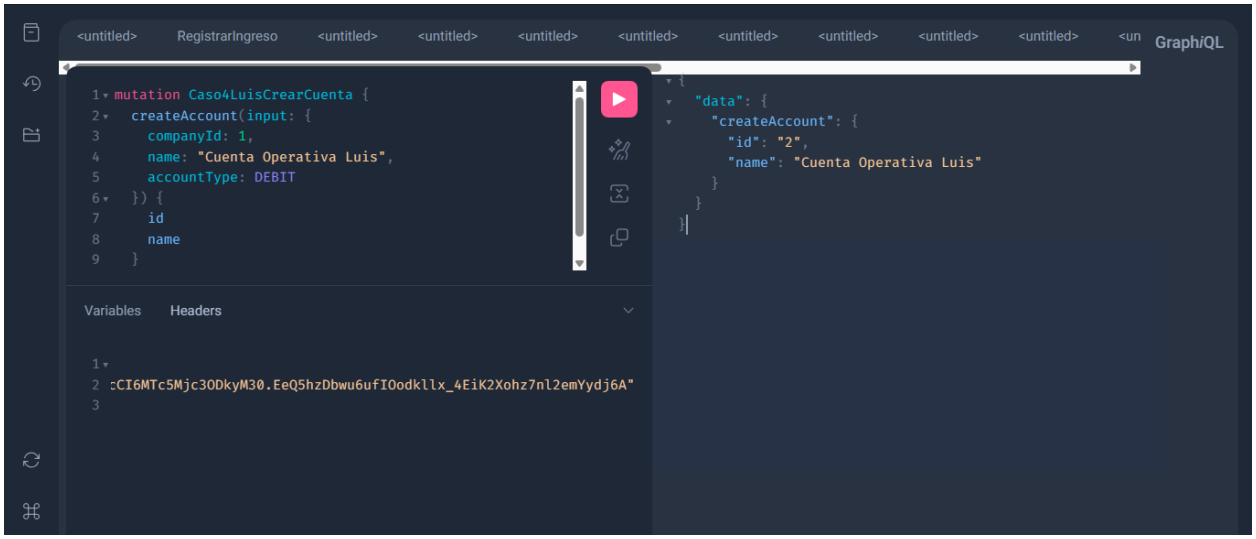
Caso 3: createAccount rechazado a María por falta de permiso accounts.write.

Regla que demuestra: Principio de menor privilegio; el rol CAPTURISTA carece de accounts.write y el servidor impide la escritura.

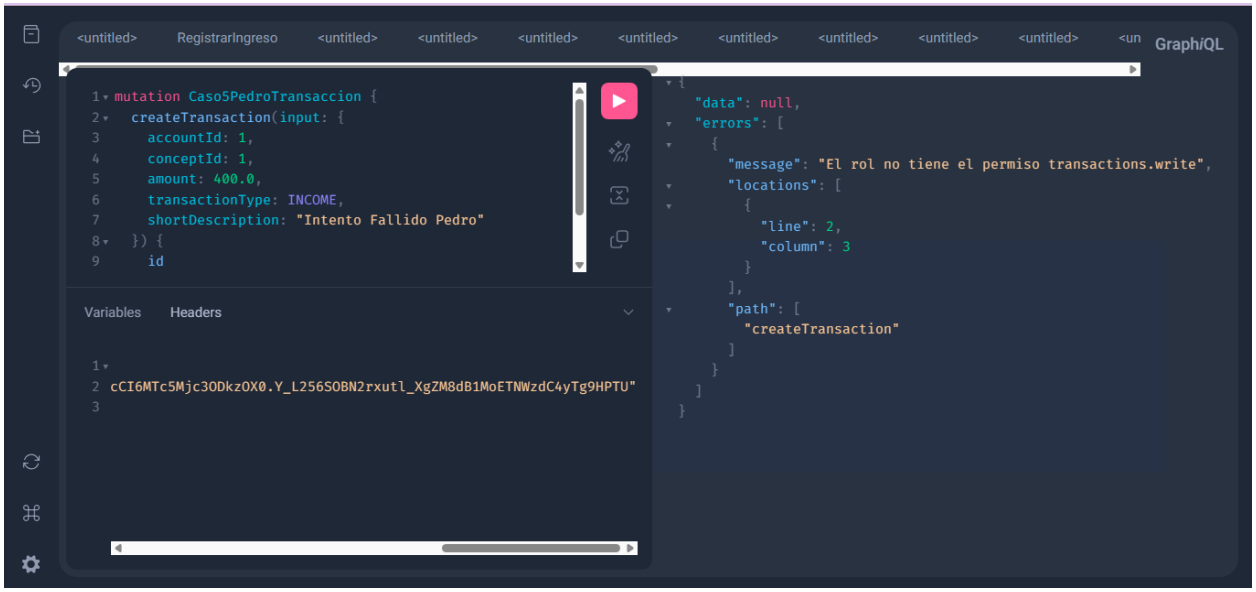



```
dad-3---Roles-y-Control-de-Acceso> cd '.\Actividad06-JWT
Tokens\'
PS C:\Users\cetza\ArqSoft-DevBack\U2_Actividad4\U2-Activi
dad-3---Roles-y-Control-de-Acceso\Actividad06-JWT Tokens>
 python -c "import sqlite3; conn=sqlite3.connect('sistema
.db'); r=conn.cursor().execute(open('consulta.sql', encod
ing='utf-8').read()).fetchall(); print(f'Filas encontrada
s: {len(r)}'); print(r)"
Filas encontradas: 0
[]
PS C:\Users\cetza\ArqSoft-DevBack\U2_Actividad4\U2-Activi
dad-3---Roles-y-Control-de-Acceso\Actividad06-JWT Tokens>
```

Caso 4: createAccount exitoso ejecutado por Luis (Rol Contador).
Regla que demuestra: Diferenciación de accesos por rol; el rol CONTADOR sí cuenta con el permiso accounts.write.

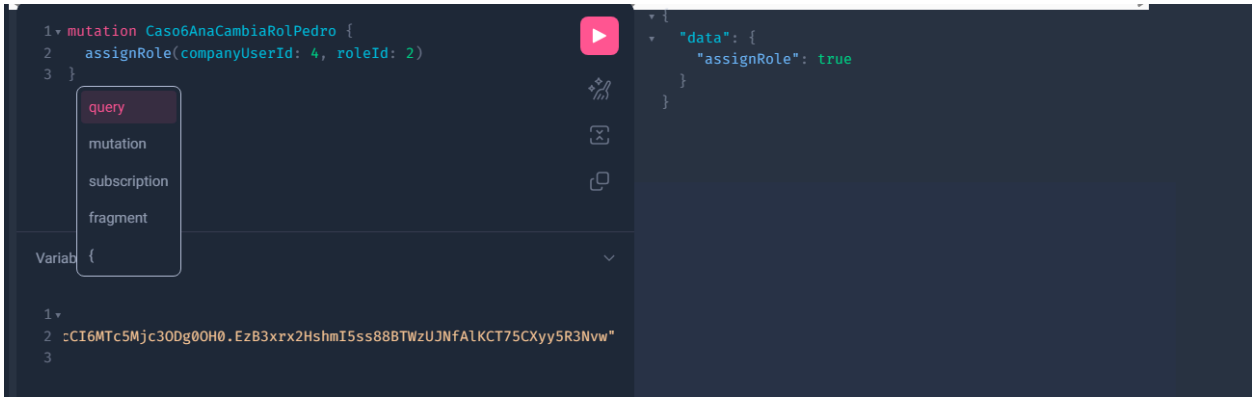


Caso 5: createTransaction rechazado a Pedro (Rol Consulta).
Regla que demuestra: Restricción de escritura; el perfil CONSULTA solo tiene lectura y no posee transactions.write.



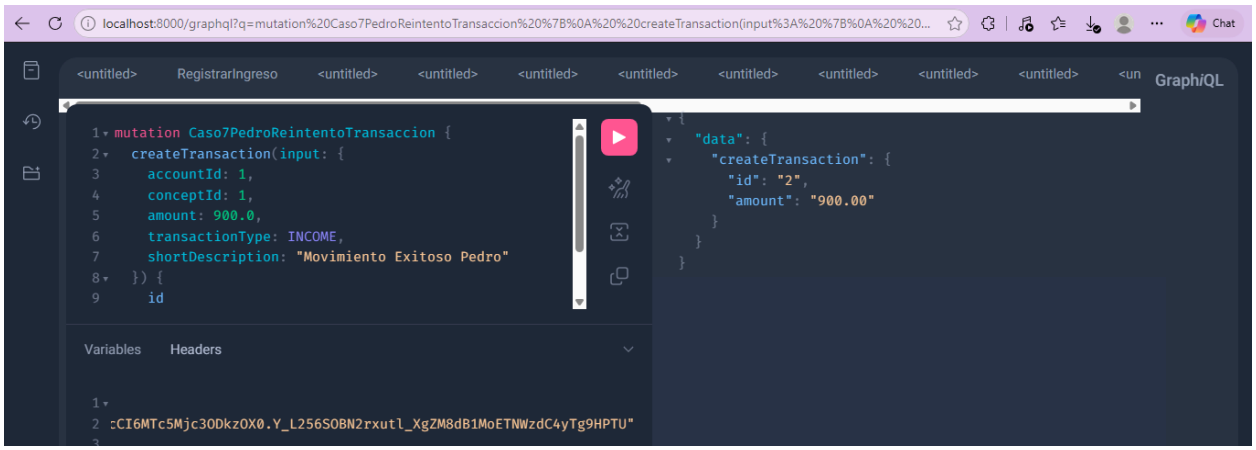
```
PS C:\Users\cetza\ArqSoft-DevBack\U2_Actividad4\U2-Activi
dad-3---Roles-y-Control-de-Acceso\Actividad06-JWT Tokens>
 python -c "import sqlite3; conn=sqlite3.connect('sistema
.db'); r=conn.cursor().execute(open('consulta.sql', encod
ing='utf-8').read()).fetchall(); print(f'Filas encontrada
s: {len(r)}'); print(r)"
Filas encontradas: 0
[]
PS C:\Users\cetza\ArqSoft-DevBack\U2_Actividad4\U2-Activi
dad-3---Roles-y-Control-de-Acceso\Actividad06-JWT Tokens>
```

Caso 6: Ana (Admin) actualiza el rol de Pedro a CAPTURISTA con assignRole.
Regla que demuestra: Gestión de roles en base de datos; la operación exige el permiso roles.write.

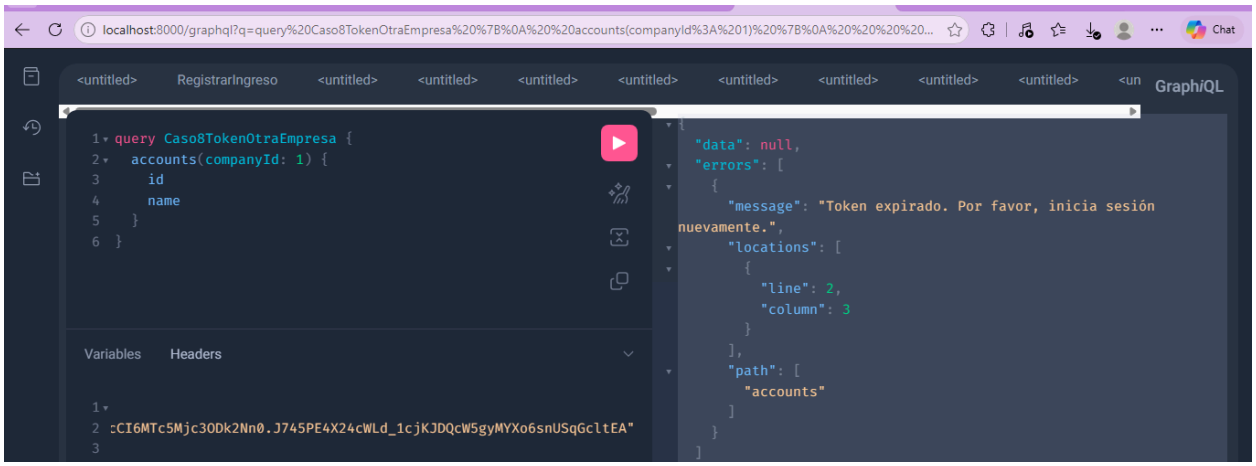



```
PS C:\Users\cetza\ArqSoft-DevBack\U2_Actividad4\U2-Activi
dad-3---Roles-y-Control-de-Acceso\Actividad06-JWT Tokens>
 python -c "import sqlite3; conn=sqlite3.connect('sistema
.db'); r=conn.cursor().execute(open('consulta.sql', encod
ing='utf-8').read()).fetchall(); print(f'Filas encontrada
s: {len(r)}'); print(r)"
Filas encontradas: 1
[(4, 'pedro@empresa.test', 'CAPTURISTA', 1)]
PS C:\Users\cetza\ArqSoft-DevBack\U2_Actividad4\U2-Activi
dad-3---Roles-y-Control-de-Acceso\Actividad06-JWT Tokens>
```

Caso 7: Pedro registra createTransaction exitosamente usando su token previo.
Regla que demuestra: Consulta de rol en tiempo real; el JWT solo transporta la membresía y el nuevo rol se lee de la BD en cada petición sin requerir nuevo login.



Caso 8: Consulta de accounts rechazada por token perteneciente a otra empresa.
Regla que demuestra: Aislamiento multitenant; un token emitido para companyId: 2 no puede acceder a las cuentas de companyId: 1.



Caso 9: createAccount rechazado por firma JWT alterada o inválida.
Regla que demuestra: Validación de firma HS256; cualquier alteración de caracteres invalida la firma criptográfica y detiene la petición.

